

CMT 446 – Information Systems Audit

Module 5: Business Continuity, Disaster Recovery & Regulatory Compliance

Duration: 1 Hour

Standards Alignment: ISO 22301, ISACA Audit Domain 5

CMT 446 – Information Systems Audit

Module 5: BCP, DR & Regulatory Compliance

BCP Audit



Business Impact Analysis

RTO & RPO



DR Audit



Data Backup



Recovery Tests

Compliance Checks



Regulatory Requirements



Audit Evidence

Key Takeaway:

***“No tested continuity =
Unprepared for crisis.”***

ISO 22301

ISACA Domain 5

Lecture Objectives

Students will be able to:

- Audit BCP and DR frameworks
 - Assess organizational resilience
 - Evaluate regulatory compliance readiness
 - Identify common continuity audit failures
-

Lecture Breakdown

0 – 10 min | Why Continuity Is an Audit Issue

Key Message

- BCP ≠ IT issue; it is **enterprise survival**

Key Drivers

- Operational resilience
- Regulatory mandates
- Stakeholder assurance

Prompt

- Why do regulators penalize firms even when no disaster occurs?
-

10 – 25 min | Business Continuity Planning (BCP)

Core Components

- Business Impact Analysis (BIA)
- Critical process identification
- RTO & RPO definitions

Audit Focus Areas

- Management ownership
- Documentation quality
- Testing frequency

Common Audit Finding

- “BCP exists but has never been tested”
-

25 – 40 min | Disaster Recovery (DR) Audits

DR Scope

- Data backups
- Infrastructure recovery
- Application restoration

Audit Techniques

- Walkthroughs
- Evidence inspection
- Simulation review

Red Flags

- Backup ≠ Recovery
 - Vendor dependency risk
 - Unrealistic RTOs
-

40 – 55 min | Regulatory & Compliance Audits

Examples

- Financial regulators
- Data protection authorities
- Healthcare regulators

Audit Evidence

- DR test reports
- Incident logs
- Regulatory filings

Professional Judgment

- When to escalate findings
 - Materiality in continuity risks
-

55 – 60 min | Wrap-Up

Exam Tip

- Always link continuity failures to **business impact**

Key Takeaway

“An organization without tested continuity plans is already in crisis.”

Module 5: BCP, DR & Regulatory Compliance

(10 CAT-style Scenario Questions)

1. An organization has a documented BCP but has never tested it.
 - a) Identify two audit findings.
 - b) Classify the risk severity.
2. During a DR audit, backups are confirmed but recovery testing is missing.
Explain why this is a critical audit issue.
3. A financial institution reports an RTO of 1 hour, but past incidents show recovery takes 8 hours.
 - a) What audit concern arises?
 - b) What evidence would you request?
4. A regulator requests proof of operational resilience compliance.
List three audit artefacts you would present.
5. A third-party cloud provider manages DR for the organization.
Explain the auditor's responsibility in this scenario.
6. Management insists BCP testing is "too expensive."
Respond as an auditor using business impact reasoning.
7. A DR test was conducted, but results were not documented.
Explain why undocumented testing fails audit requirements.
8. An organization passes cybersecurity audits but fails a continuity audit.
Explain how this situation is possible.
9. During a crisis, staff do not follow the BCP.
 - a) Identify the root cause.
 - b) Recommend an audit-driven corrective action.
10. Explain why **BCP and DR failures are considered governance failures**, not IT failures.